

Comprehensive Bank Policy Framework

Applicable to Banks Operating in Portugal under Banco de Portugal and ECB (SSM) Supervision

I. GOVERNANCE & OVERSIGHT POLICIES (ECB CORE REQUIREMENT)

1. Corporate Governance Policy

This policy defines how the bank is directed and controlled.

Must clearly set out:

Roles and responsibilities of:

- Board of Directors

Executive Management

- Committees (Audit, Risk, Remuneration, Nomination)

Separation between oversight and executive functions

Decision

- making processes and delegation of authority

Frequency and documentation of meetings

Accountability mechanisms

ECB focus: effective challenge by the Board, not rubber-stamping.

2. Internal Governance & Control Framework Policy

Defines how the bank controls itself internally.

Must include:

Escalation and remediation processes

Internal reporting standards

3. Fit & Proper (Suitability) Policy

Ensures that board members and senior managers are suitable.

Covers:

Initial and ongoing assessments

Integrity, honesty, reputation

Competence, experience, time commitment

Collective suitability of the board

Handling of adverse findings

Mandatory for ECB approvals.

II. RISK MANAGEMENT POLICIES (SREP CRITICAL)

4. Risk Management Framework (RMF) Policy

The backbone of the risk system.

Includes:

Risk taxonomy (credit, market, liquidity, operational, ICT, ESG, etc.)

Risk identification processes

Risk measurement methodologies

Risk monitoring and reporting frequency

Risk culture principles

5. Risk Appetite Framework (RAF) Policy

Defines how much risk the bank is willing to take.

Must specify:

Quantitative limits (capital, losses, liquidity, NPL ratios)

Qualitative statements

Limit breaches and escalation

Board approval and review cycle

ECB expects strong linkage to strategy.

6. Credit Risk Policy

Controls all lending activities.

Must cover:

Credit approval authorities

Credit analysis standards

Collateral valuation

Single-name and sector concentrations

Loan classification and impairment

Monitoring and recovery processes

7. Operational Risk Policy

Controls non-financial risks.

Includes:

Identification of operational risk events

Loss data collection and thresholds

Risk and Control Self-Assessments (RCSA)

Key Risk Indicators (KRIs)

Operational risk reporting

III. CAPITAL, LIQUIDITY & PRUDENTIAL POLICIES

8. ICAAP Policy

Internal Capital Adequacy Assessment.

Must contain:

Capital planning horizon (minimum 3 years)

Risk coverage beyond Pillar 1

Stress testing methodologies

Capital buffers and contingency actions

9. Liquidity & Funding Risk Policy

Ensures the bank can meet obligations.

Covers:

LCR / NSFR governance

Funding sources diversification

Liquidity stress scenarios

Contingency Funding Plan (CFP)

10. Recovery Plan Policy

Used in financial distress situations.

Includes:

Recovery indicators

Recovery measures and feasibility

Crisis governance structure

Alignment with resolution authorities

IV. COMPLIANCE, ETHICS & CONDUCT POLICIES

11. Code of Conduct & Ethics Policy

Defines acceptable behaviour.

Covers:

Integrity and professionalism

Conflicts of interest

Gifts and hospitality

Market abuse

Disciplinary consequences

Mandatory training annually.**12. Compliance Policy**

Defines the role of the Compliance Function.

Includes:

Regulatory monitoring

Compliance risk assessment

Advisory and challenge role

Reporting to senior management and board

13. Conflicts of Interest Policy

Prevent personal interests harming the bank.

Includes:

Identification and disclosure

Management of related-party transactions

Personal account dealing

Register of conflicts

14. Whistleblowing Policy

Protected reporting of misconduct.

Must ensure:

Confidential channels

Protection from retaliation

Clear investigation processes

Reporting to competent authorities if required

V. AML / CTF & FINANCIAL CRIME POLICIES (LEGAL REQUIREMENT)

15. AML / CTF Policy

Top-level framework.

Aligned with Portuguese Law 83/2017 and EU AML rules.

Includes:

Governance and accountability

Risk-based approach

Reporting obligations

16. Customer Due Diligence (CDD / KYC) Policy

Identifies who customers really are.

Includes:

Identification and verification rules

Beneficial owner determination

Ongoing monitoring

Low, medium, high risk categorisation

17. Enhanced Due Diligence (EDD) Policy

For high-risk customers.

Includes:

PEPs

High-risk jurisdictions

Source of funds/wealth verification

Senior management approval

18. Transaction Monitoring & STR Policy

Detects and reports suspicious activity.

Includes:

Monitoring rules

Alerts handling

Reporting to UIF

Record retention

VI. ICT, CYBER & OPERATIONAL RESILIENCE (DORA)

19. ICT Risk Management Policy

Controls IT-related risks.

Includes:

System reliability and availability

Change management

Access controls

Incident reporting

20. Cybersecurity Policy

Protects against cyber threats.

Includes:

Threat detection

Incident response

Penetration testing

Staff awareness

21. Business Continuity & Disaster Recovery Policy

Ensures operations continue during crises.

Includes:

Business Impact Analysis (BIA)

Recovery Time Objectives (RTO)

Crisis management teams

Regular testing

22. Outsourcing & Third-Party Risk Policy

Critical for cloud and service providers.

Includes:

Due diligence

Risk classification

Contractual safeguards

Exit strategies

VII. DATA, GDPR & RECORD KEEPING

23. Data Protection (GDPR) Policy

Ensures lawful data processing.

Includes:

Lawful bases

Data subject rights

Role of DPO

Supervisory authority notification

24. Data Retention Policy

Controls how long records are kept.

Aligned with:

AML retention rules

Prudential requirements

GDPR principles

VIII. INTERNAL AUDIT & ASSURANCE

25. Internal Audit Policy & Charter

Ensures independent oversight.

Includes:

Audit independence

Annual audit plan

Reporting lines to the Board

Follow-up of findings

IX. HR & REMUNERATION (ECB VERY SENSITIVE)

26. Remuneration Policy

Must discourage excessive risk-taking.

Includes:

Fixed/variable pay split

Malus and clawback

Remuneration committees

Compliance with EU remuneration rules

27. Training & Competence Policy

Ensures staff competence.

Includes:

Mandatory compliance training

AML, ethics, risk

Documentation of attendance

X. CONSUMER PROTECTION & CONDUCT OF BUSINESS

28. Consumer Protection Policy

Protects retail clients.

Includes:

Transparency

Fair treatment

Marketing standards

29. Complaints Handling Policy

Manages customer complaints.

Includes:

Timelines

Documentation

Reporting to regulators if required

XI. ESG & CLIMATE (INCREASING ECB EXPECTATIONS)

30. ESG & Climate Risk Policy

Integrates sustainability risks.

Includes:

Identification of climate risks

Integration into risk management

Long-term impact assessment

1. Legal Basis (Mandatory Reference Section)

All processes involving customer onboarding, account opening, product access, or establishment of a business relationship **must comply with the following binding legal requirements:**

- **Directive (EU) 2015/849 (AMLD)** – Article 13
- **Regulation (EU) 2024/1624 (AMLR)** – Articles on customer due diligence
- **Portuguese Law No. 83/2017**, of 18 August – Articles 23–28
- Banco de Portugal supervisory enforcement of Law 83/2017

These legal acts require that **Customer Due Diligence (CDD)** only must be applied **before the relationship is approved or activated.**

2. Binding Process Rule (Non-Negotiable)

The Bank **SHALL NOT** approve, activate, or establish a business relationship with a customer unless Customer **Due Diligence** has been fully completed and confirmed.

This rule is:

- Legally binding
- **Process-blocking**
- Not subject to management discretion

Any deviation constitutes a **regulatory breach**, not merely a process defect.

Any deviation constitutes a **regulatory breach**, not merely a process defect.

3. Definition for Process Purposes (Critical)

For all Bank processes, the following definitions apply:

“Customer Due Diligence (CDD) completed”

Means that:

- Customer identity has been verified
- Beneficial owner has been identified and verified (where applicable)
- Purpose and intended nature of the relationship are understood
- AML risk classification has been assigned
- Required approvals for normal / enhanced due diligence have been obtained

“Establishing a Business Relationship”

Means:

- Formal **approval of onboarding**, OR
- Account creation or activation, OR
- Granting access to banking services

The Bank explicitly considers onboarding approval as the moment the business relationship is established.